

Enterprise Multi-Tenant AI Knowledge Assistant

End-to-end architecture, deployment plan and pilot request | Lead AI Solutions Architect

Build a governed platform, starting with a pilot

RECOMMENDATION

A provider-neutral AI platform built as regional cells: AWS primary, Azure warm standby, hybrid models behind one gateway.

1

One gateway, many models

Models are replaceable; identity, policy, data and audit stay ours.

2

Authorization before inference

Content a user cannot see never reaches a model.

3

Prove it before scaling

Quality, security and cost gates decide each expansion.

12–14 wk

foundation and pilot
before any global
funding

0

cross-tenant or critical
PII leaks tolerated

99.95%

platform availability
target in production

Six requirements that pull against each other

1 Accuracy

Answers grounded in authoritative enterprise data, with citations.

2 Security and privacy

Users and agents only ever see data they are authorized to see.

3 Data locality

Restricted data stays inside its approved jurisdiction, including in DR.

4 Speed and availability

Predictable latency in SLA regions and service that survives failures.

5 Agent safety

No high-impact action without deterministic policy and human approval.

6 Cost and portability

Frontier capability without dependence on one model or cloud.

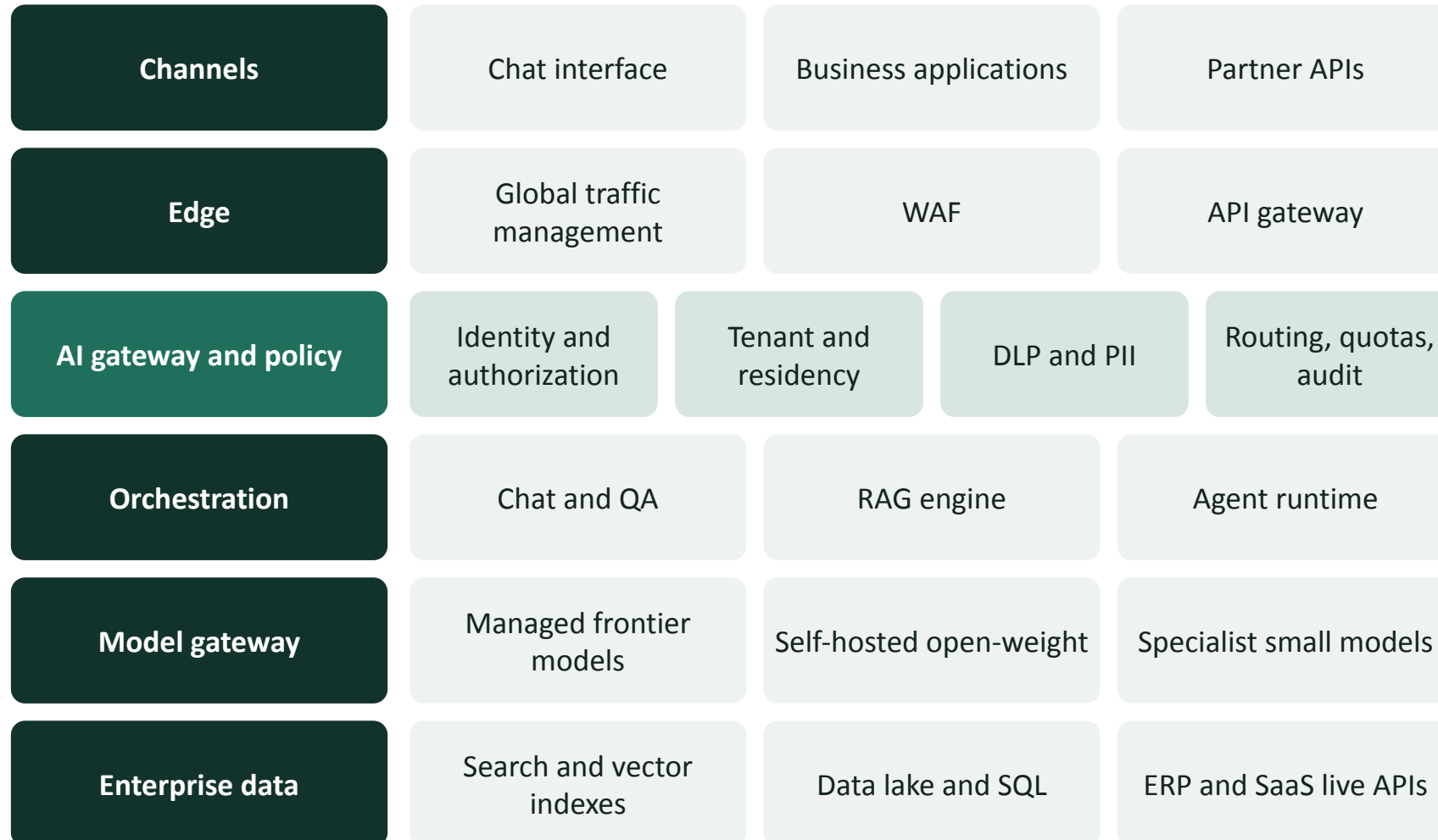
Hybrid model hosting behind one gateway

Option	Strengths	Trade-offs	Use it for
Cloud-managed frontier	Top capability, fast to deploy, elastic	Token cost, provider dependency, residency limits	Complex reasoning, general chat
Self-hosted open-weight	Full control and locality, steady unit cost	GPU spend, MLOps burden, lower capability	Restricted data, steady high volume
Hybrid (recommended)	Balances capability, sovereignty and cost	More platform to run	The enterprise default

Decision

Applications never call a model vendor directly. The gateway routes each request by data classification, jurisdiction, task difficulty and cost, so a model can be swapped without touching apps.

Reference architecture: one stack per regional cell



Regional cells

- Each region runs the full stack, so data, retrieval and inference stay in-jurisdiction
- AWS cells are primary, multi-AZ
- Azure cell is warm standby with equivalent models and separate keys
- A failure stays inside one cell

Retrieval keeps answers current and private

1 Batch ingestion

Documents are scanned, parsed, classified, chunked and indexed with their access lists attached.

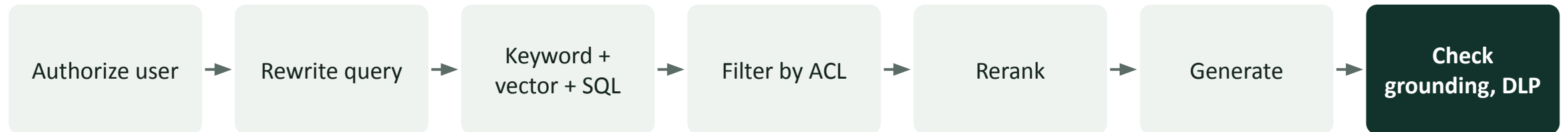
2 Change capture

ERP and data-lake changes stream in and update indexes incrementally, within minutes.

3 Live retrieval

Balances, inventory and workflow status come from the system of record at request time.

QUERY PATH



Why not fine-tune? Fine-tuning suits stable style, terminology and classification. It cannot enforce permissions, cite sources or keep up with daily ERP changes.

Security controls on every data flow

Identity and access

- Enterprise IdP with MFA
- RBAC plus attributes: tenant, role, jurisdiction, purpose
- Short-lived workload identities between services

Key management

- Customer-managed keys per jurisdiction and sensitive tenant
- HSM-backed, held separately in AWS and Azure
- Rotation, and key destruction on tenant exit

Encryption and network

- TLS in transit, envelope encryption at rest
- Private links to on-prem ERP
- No public endpoints for model or index traffic

PII handling

- Detected before inference and before response
- Allow, redact, tokenize or block by policy
- Prompts and outputs kept out of general logs

Tenant isolation matched to tenant risk

Isolation, and cost, rise with the tenant's regulatory exposure.

Tier 1

Shared, partitioned

- Shared infrastructure
- Tenant ID enforced on every query and index filter
- Standard business units

Tier 2

Dedicated data

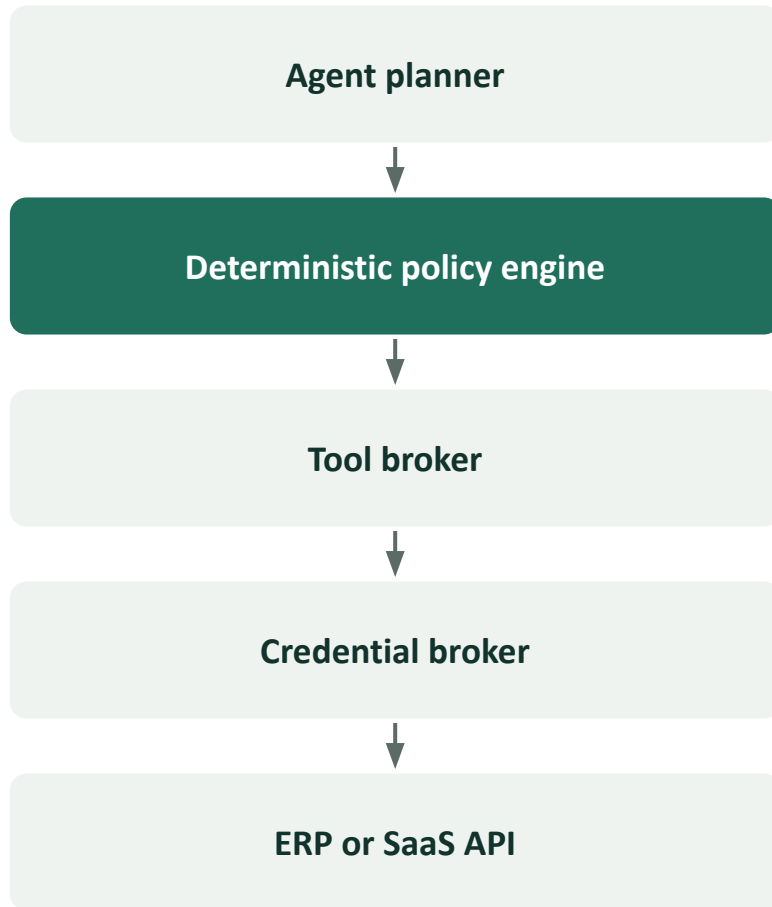
- Shared compute
- Own indexes, databases and encryption keys
- Sensitive tenants: finance, HR, legal

Tier 3

Dedicated environment

- Own cloud account, network, stores and keys
- Optional dedicated inference
- Highly regulated tenants

Agents act only through policy and narrow tools



Action class	Examples	Control
Read-only	Invoice status, report data	Automatic, fully logged
Reversible write	Open ticket, draft purchase order	Policy check, value and rate limits
High-impact	Payment, posting, master data	Human approval, dual control

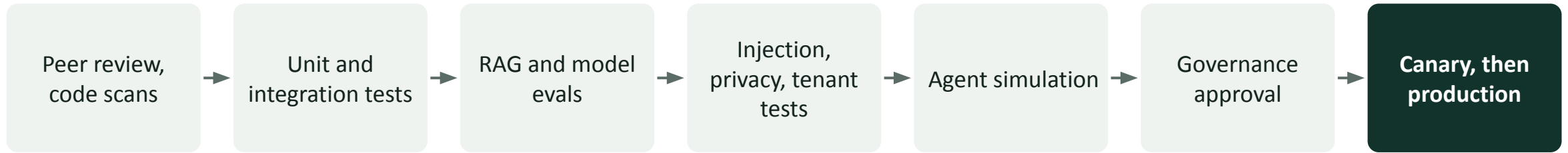
On every run

- Tools are business functions, never raw SQL or shell
- Retrieved documents and tool output are treated as untrusted input
- Step, spend and time limits, plus a kill switch per agent and tenant
- Every proposal, approval and execution lands in an immutable audit log

What we measure, and the bar each must clear

Metric	Target	How it is measured
Grounded, correct answers	$\geq 95\%$	Curated evaluation set plus sampled human review
Citation correctness	$\geq 98\%$	Automated check that each claim is in its cited source
Cross-tenant or critical PII leaks	0	Planted canary records, red-team suites, output DLP
Unauthorized agent actions	0	Policy-engine decisions reconciled against tool calls
Latency in SLA regions	$p95 \leq 3\text{ s}$	Tracing of first token and full response, per cell
Platform availability	$\geq 99.95\%$	Synthetic probes and error budgets per cell
Cost per resolved task	30–50% below pilot	Gateway metering joined to task outcomes

Governance runs inside the delivery pipeline



Version everything

Models, prompts, agents, retrieval settings, evaluation sets and policies live in one registry with risk class and approved regions.

Approval workflow

High-risk agent changes need AI governance, security and the system owner. A newer model ships only if it beats the incumbent.

Structured traces

Log identity, model, prompt and policy versions, sources, tool calls and approvals in-region, not raw chain-of-thought.

Incident response and failover to Azure

$\leq 1\text{ h}$

recovery time, region loss (proposed)

$\leq 15\text{ min}$

data loss window for indexes (proposed)

Locality still applies in DR: restricted tenants fail over only in-jurisdiction, or run read-only.

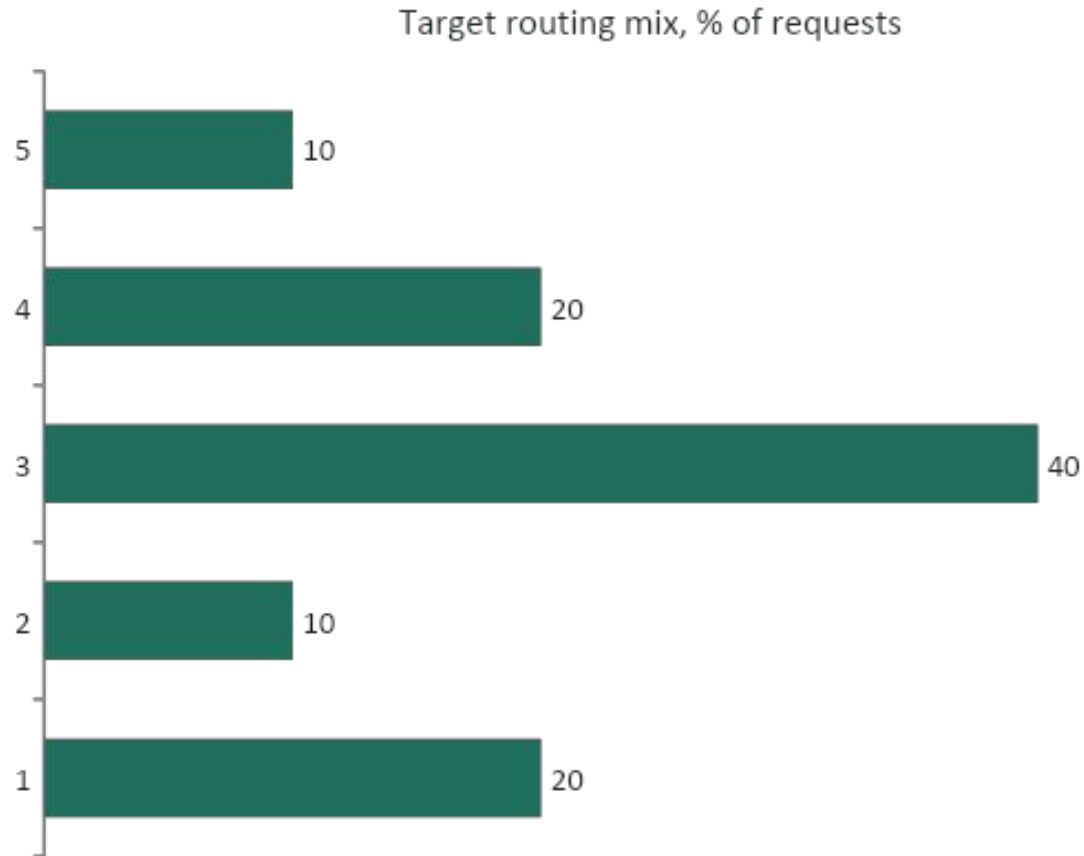
Failover sequence

- 1 Detect: probes and error budgets
- 2 Decide: automatic for zone loss, declared for region loss
- 3 Shift traffic to the Azure cell
- 4 Run on equivalent models, replicated indexes; pause write agents
- 5 Reconcile, then fail back

AI incident playbooks

- Data leak: isolate tenant, revoke keys and tokens, notify within the legal window
- Prompt injection or bad agent action: kill switch, credential revoke, reverse the action
- Quality regression: roll back model or prompt version
- Provider outage: gateway reroutes to the next approved model

Route by difficulty to cut cost per resolved task



Planning assumption; the pilot replaces it with measured traffic.

Cost levers, in order

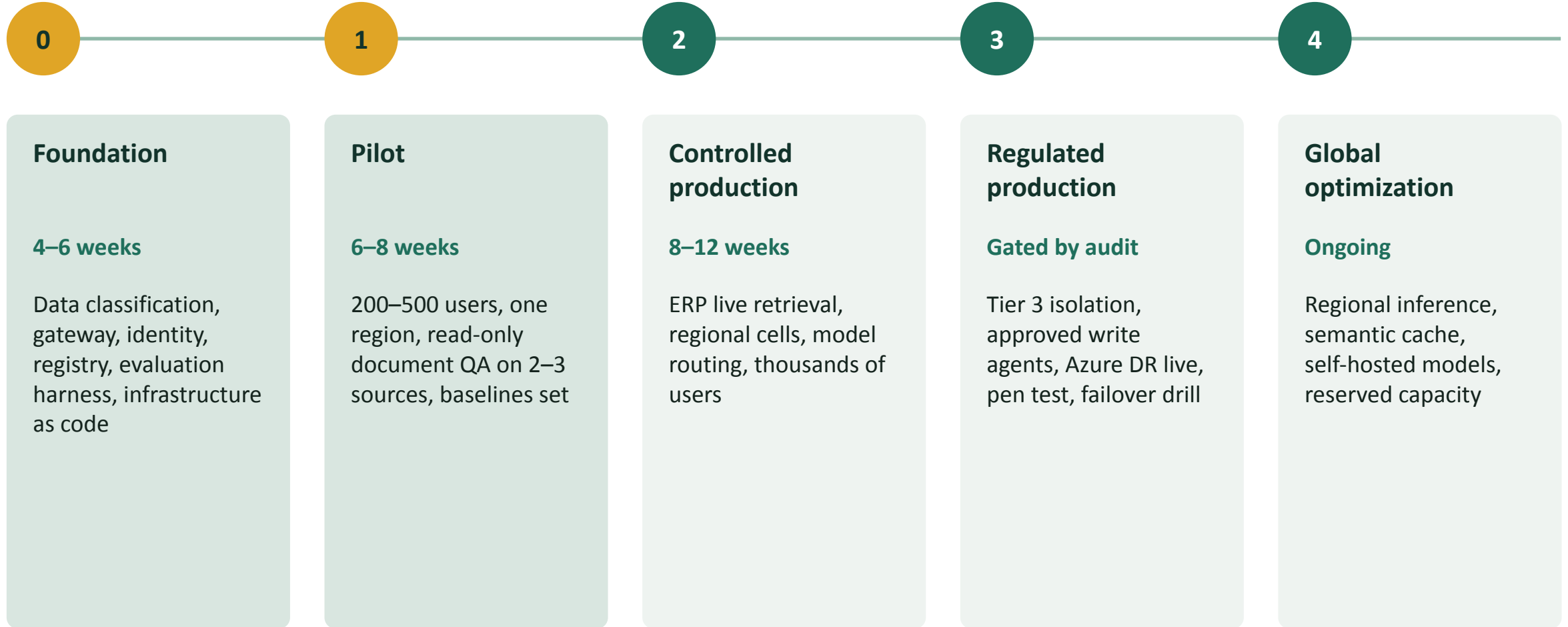
- 1 Semantic cache**
Repeat questions answered without a model call.
- 2 Tiered routing**
Frontier models only for requests that need them.
- 3 Self-host steady load**
Move predictable volume to owned GPUs once utilization justifies it.
- 4 Reserved capacity**
Commit only after demand is measured.

Main risks and compliance challenges

Risk or challenge	How the design answers it
Cross-tenant or PII leakage	Access filter before inference, tiered isolation, leak tests on every release
Prompt injection through documents or tools	Untrusted-content handling, narrow tools, deterministic policy engine
Residency breach via DR or managed models	Jurisdiction-pinned routing, in-region DR, contractual processing limits
Erasure and retention duties	Lineage from source record to chunk, deletes propagated to indexes and logs
Changing AI and privacy regulation	Model risk classes, asset registry, audit evidence from the pipeline
Vendor lock-in and price shifts	Gateway abstraction, portability test in every model evaluation
DR that fails when needed	Azure cell deployed by the same pipeline, scheduled failover exercises

From pilot to global production in five phases

Phases 0 and 1 are the pilot requested today



The ask: approve a 12–14 week pilot

Approve

- One AWS region, one business unit, 200–500 users
- Two or three high-value data sources
- Two managed models and one open-weight model, compared head to head
- Read-only RAG and low-risk agents only
- A cross-functional team: architecture, platform, security, data, IAM, compliance, SRE, product

Advance to production only if

- $\geq 95\%$ grounded answers and $\geq 98\%$ correct citations
- Zero cross-tenant or critical PII leaks
- p95 latency inside the regional SLA
- Design shown able to reach 99.95% availability
- A model swapped through the gateway with no app changes
- Projected cost per resolved task on target
- Security, privacy and compliance sign-off

Models can change. Our security boundary, data ownership and regulatory controls do not.